

Information Security Policy

SIMULATED / FICTIONAL EVIDENCE — FOR EDUCATIONAL USE ONLY

Organization	CloudFlow Technologies (fictional SaaS vendor)
Product in scope	CloudFlow CRM
Classification	Confidential — Internal Use / Simulated Evidence
Approval status	Approved for simulation (not a live corporate record)
Document owner	Jordan Hale, Chief Information Security Officer
Document ID	POL-IS-001
Version	3.2
Effective date	15 January 2025
Last review date	15 January 2026
Next review	15 January 2027

1. Purpose

This policy establishes CloudFlow Technologies' information security governance for the CloudFlow CRM SaaS platform and supporting AWS environment. It assigns accountability for protecting customer and employee information classified as Confidential. This document is simulated for an educational third-party risk assessment case study and does not describe a real company.

2. Security governance

The Chief Information Security Officer (CISO) is accountable for the information security management system (ISMS). A Security Steering Committee, chaired by the CISO, meets quarterly. Engineering, Infrastructure, Legal, and Customer Success hold defined RACI responsibilities. CloudFlow maps selected controls to NIST Cybersecurity Framework functions, ISO/IEC 27001 control concepts, and SOC 2 Trust Services Criteria as methodological guidance. CloudFlow does not claim ISO/IEC 27001 certification.

3. Roles and responsibilities

- CISO: policy ownership, risk acceptance above defined thresholds, customer security communications.
- Director of Security: operations, vulnerability management, incident command, awareness training.
- Director of Infrastructure: AWS baseline, backups, recovery design, capacity.
- Engineering leads: secure SDLC, code review, application tenant isolation.
- All personnel: acceptable use, reporting of suspected incidents within 2 hours of awareness.

4. Policy suite and review

Core policies include access control, data protection, incident response, vulnerability management, acceptable use, and business continuity. Policies are reviewed at least annually or after material change. The 15 January 2026 review confirmed POL-IS-001, POL-AC-002, IRP-001, BCP-001, POL-VM-005, and STD-DP-004. Supporting work instructions for two secondary standards did not include complete sign-off packets at the time of this simulated evidence pack, which

an assessor may treat as a documentation completeness gap rather than an absent program.

5. Human resources security

Employees complete mandatory security awareness training at hire and annually thereafter, with two phishing simulations per year. CloudFlow does not currently operate a continuous micro-learning program. Background screening is performed for employees in the United States and United Kingdom consistent with local law. Violations of this policy may result in disciplinary action up to termination.

6. Related documents

POL-AC-002 Access Control Policy; IRP-001 Incident Response Plan; BCP-001 Business Continuity Plan; POL-VM-005 Vulnerability Management Policy; STD-DP-004 Data Protection Standard.